

A01: Broken Access Control

Weakness:

The teacher and admin panel does not have proper user role validation. Because of this, regular players can access the teacher or admin panel by simply modifying the URL, and may perform administrative tasks.

The Affected System Area is the admin, teacher, and student panel

Security We apply:

Update the source code to enforce proper role-based access control, add a user role verification check, and strengthen user authentication to prevent unauthorized access

A02: Security Misconfiguration

Weakness 1:

The `.env` file contains secret keys and system configuration details. If it is publicly exposed, attackers may steal sensitive credentials, access confidential settings, or exploit the system configuration to gain unauthorized access.

The Affected System Area is the `Environment configuration file`

Restrict public access to the `.env` file by implementing proper server access controls, such as `.htaccess` rules or web server configurations. This helps prevent unauthorized users from directly accessing sensitive credentials, API keys, and system configuration details through the browser.

Weakness 2:

The login error message shows exactly which part of the entered credentials is incorrect. This may help attackers identify valid usernames or emails and perform brute-force attacks on the login page.

The affected area is the Login Page, specifically the login error message.

Modify the login error message to use a generic warning, such as "Invalid login credentials" This prevents the system from revealing which credential input is incorrect.

Weakness 3:

The default admin login credentials are still being used. This makes it easier for attackers to guess the admin username or password and gain access to perform administrative tasks.

The affected area is the **Admin panel and login credentials**.

Implement mandatory password changes during admin account setup and enforce strong password complexity requirements. This ensures default passwords are replaced with secure credentials, reducing the risk of unauthorized access and credential-guessing attacks.

A03: Software Supply Chain Failures

Weakness 1:

The system is using an outdated and unsupported version of the SimpleJWT package. This may cause compatibility issues, system errors, and potential security risks due to missing updates and patches.

The affected system area is the **Forgot Password** feature, which may fail to function properly because of the outdated package version.

Update the SimpleJWT package to the latest supported version to resolve system errors, improve compatibility, and ensure the Forgot Password feature functions securely and reliably. Additionally, always use packages from official sources, and verify software integrity before installation.

A04: Cryptographic Failures

Weakness:

During registration, the system stores user passwords in the database in plain text format. This is a high-risk vulnerability because if a database breach occurs, attackers can directly view the leaked passwords. These credentials may be used to access the users' accounts in the system and may also be reused to access their accounts on other platforms.

The affected area is the User Registration process and the password storage in the database.

Update the system to securely hash passwords before storing them in the database using strong hashing algorithms. This helps protect user credentials and prevents attackers from directly viewing passwords if a database breach or unauthorized access occurs.

A05: Injection

Weakness 1:

The system login page accepts user input without proper sanitization and does not use parameterized SQL queries. This creates a high risk of SQL injection, where attackers may manipulate the login query and gain unauthorized access.

The affected area is the **Login Page** Form

Sanitize and validate all user inputs before processing them in the system. Use parameterized queries or prepared statements to prevent SQL injection attacks, reduce malicious input risks, and ensure user data is handled securely and reliably.

Weakness 2:

The comment feature displays comments from the database without proper output encoding. This results in a Cross-Site Scripting or XSS vulnerability, where attackers may inject malicious scripts that can run in the user's browser. This can be used to steal session cookies, redirect users to harmful websites, or perform unauthorized actions.

The affected area is the **Comment Feature**, specifically the **comment display/list section**.

Apply proper output encoding before displaying comments on the page to prevent malicious scripts from executing in the user's browser. Sanitize and validate all user inputs, escape harmful characters, and implement secure input handling to reduce the risk of Cross-Site Scripting (XSS) attacks and unauthorized actions.